



Weekly Cyber Threat Intelligence Report

Reporting window: 17 July - 24 July 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary

1 Critical CVEs	3 High-sev vulns	3 Actively exploited	1 Notable breaches	1 PoCs / tools	9 IOCs to add
--------------------	---------------------	-------------------------	-----------------------	-------------------	------------------

This reporting window was defined by **same-day weaponisation of a pre-auth RCE in default-install software**, a widening **AI-agent attack surface at the memory layer**, and **developer supply-chain targeting**. The headline item is **wp2shell** (CVE-2026-63030, chained with the CVE-2026-60137 SQLi): an unauthenticated pre-auth RCE reachable on a default WordPress 6.9.0-7.0.1 site with zero plugins. Emergency releases 7.0.2/6.9.5 shipped on the 17 Jul disclosure date and WordPress.org forced automatic updates, yet multiple firms report **in-the-wild exploitation and public PoC exploit code within hours** (a public exploit toolkit is on GitHub). On the AI front, **MemGhost** shows a single email can plant persistent false memories in inbox-reading agents (OpenClaw's AGENTS.md/MEMORY.md), with 87.5% success against OpenClaw+GPT-5.4 - a compromise that survives context clears. Supply chain: a corroborated **North Korea-aligned (UNK_DeadDrop)** campaign lures developers into cloning malicious GitHub repos that execute at clone/open/install time. Client-side and endpoint exposure featured a **7-Zip XZ-decoder heap-overflow RCE** (CVE-2026-14266, patch 26.02) and **Citrix Secure Access/EPA privilege escalation to SYSTEM** (CVE-2026-53565/-53566); a **Perl Storable** deserialization integer overflow (CVE-2026-57433) rounds out the vulnerability set. Regionally, Kaspersky exposed the long-dwell **GoSerpent** espionage backdoor across Southeast Asian government, police and biometric systems. An unverified **600M-record Tinder** sale claim did not stand up to web corroboration and is retained unverified. **Items are ordered verified-first, each with up to three independent references**; seven of eight items were promoted to VERIFIED after web-search corroboration this run (only the Tinder claim remains unverified).

AUSTRALIA - SPECIFIC

Local orgs & advisories

No Australia items identified this reporting window.

APAC - SPECIFIC

Regional incidents & actors

GoSerpent backdoor - long-dwell espionage against Southeast Asian government, diplomatic, police & biometric systems

HIGH

VERIFIED

Malware

SE-Asia

Espionage

Kaspersky (Securelist) uncovered GoSerpent, a previously undocumented espionage backdoor targeting government, diplomatic, police and biometric systems across Southeast Asia. Publicly reported 17 Jul; Kaspersky first detected the activity in February 2026, with the operation running since late 2025 and some access dating back years. GoSerpent gives operators persistent, low-and-slow access and pairs with SOCKS5 proxies, the Stowaway RAT/proxy tool and credential-dumping utilities, routing traffic through compromised hosts to blend C2 and frustrate network attribution. In May 2026 the operators returned with an evolved toolset and a stealthy share-based exfiltration tool that quietly collected months of data. No firm attribution; researchers flag a possible link to the TetrisPhantom espionage cluster. Hunt for anomalous outbound relaying, Go-based low-and-slow beacons and LSASS/credential-theft activity on government and diplomatic endpoints.

PoC: Active exploitation in the wild - live espionage campaign, multi-year dwell - [securelist.com](#)

Refs: [securelist.com](#) · [thehackernews.com](#) · [cybernews.com](#)

North Korea-aligned malicious GitHub repositories (UNK_DeadDrop) target developers via fake coding assignments

HIGH

VERIFIED

SupplyChain

DPRK

DeveloperTargeting

Multiple vendors corroborate a North Korea-aligned campaign (Proofpoint tracks it as UNK_DeadDrop) that lures developers via fake recruiter pitches, 'paid trial' coding assignments and code-review requests into cloning malicious GitHub/GitLab repos that mimic real projects. Payloads execute at clone/open/install time: a hidden `.vscode/tasks.json` auto-runs when the repo is opened in VS Code or Cursor, or npm preinstall/postinstall lifecycle scripts fire - dropping infostealers/RATs (e.g. the Overlord backdoor, OtterCookie-aligned malware, malicious VSIX extensions disguised as Google services) that steal source code, cloud and CI/CD credentials, package-registry tokens and crypto wallets. Proofpoint counted 250+ phishing emails to nearly 100 organisations (finance, crypto, education, technology; mostly US) across Apr-May 2026, using spoofed/fabricated firms (Pulsynk, Trixauvex, Ondo Finance). A community dataset (@ossmalware) tracks 5,000+ DPRK-attributed repos. Never clone-and-run unsolicited code on a credentialed host - use a disposable VM/container, run installs with `--ignore-scripts`, and review `package.json` scripts and `.vscode/tasks.json` before opening.

PoC: Active exploitation in the wild - 250+ phishing emails to ~100 orgs (Apr-May 2026); clone-and-run lures - bleepingcomputer.com

Refs: bleepingcomputer.com · proofpoint.com · cybersecuritynews.com

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

Patch now

CVE-2026-63030 'wp2shell' - WordPress Core pre-auth RCE, actively exploited with public PoC

CRITICAL

VERIFIED

WordPress

RCE

Exploited

wp2shell chains CVE-2026-63030 (a REST API batch-route confusion at /wp-json/batch/v1) with CVE-2026-60137 (SQL injection in WP_Query's author__not_in parameter) for unauthenticated pre-auth remote code execution on default WordPress 6.9.0-7.0.1 installs - no plugins, no login, no special config. A malformed path in a batch sub-request makes wp_parse_url() return false, desynchronising the validation and execution arrays so later sub-requests dispatch against the wrong handlers and bypass authentication. Disclosed 17 Jul by Adam Kues (Assetnote / Searchlight Cyber); emergency releases 7.0.2 and 6.9.5 shipped the same day and WordPress.org forced automatic updates across affected installs. Multiple firms (Wiz, Greenbone) report in-the-wild exploitation, with public PoC exploit code appearing within hours. Update immediately to 7.0.2 (or 6.9.5); if patching lags, block anonymous access to /wp-json/batch/v1 and ?rest_route=/batch/v1 at the WAF and hunt web logs for unauthenticated POSTs to the batch route.

PoC: Public - exploit toolkit github.com/ikow/wp2shell; PoCs & in-the-wild exploitation within hours of 17 Jul disclosure - github.com

Refs: slcyber.io · tenable.com · rapid7.com

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

CVE-2026-53565 / -53566 - Citrix Secure Access & EPA Client (Windows) local privilege escalation to SYSTEM

HIGH

VERIFIED

Citrix

PrivEsc

Windows

Cloud Software Group disclosed two Windows-client flaws (bulletin published 14 Jul). CVE-2026-53565 (improper privilege management, CWE-269, CVSS v4.0 8.5) lets a standard, low-privileged local user of the Citrix Secure Access Client or the Citrix Endpoint Analysis (EPA) Client escalate to full SYSTEM with no user interaction and no prior elevation. CVE-2026-53566 (out-of-bounds memory read, CWE-125, CVSS 6.8) affects only Secure Access and requires the DNE (Device NetScaler Endpoint) driver to be absent. Fixed in Citrix Secure Access Client 26.6.1.20 and EPA Client 26.5.1.7; no confirmed in-the-wild exploitation at disclosure. VPN/ZTNA agents run privileged service components, so client-side privesc is a favoured post-initial-access step that converts a phishing/infostealer foothold into SYSTEM without touching the network edge. Inventory and patch these clients and hunt for suspicious child processes or DLL loads from the Citrix client service paths.

Refs: cybersecuritynews.com · gbhackers.com · cvefeed.io

CVE-2026-14266 - 7-Zip XZ decoder heap overflow -> client-side RCE (patch 26.02)

HIGH

VERIFIED

7-Zip

RCE

ClientSide

CVE-2026-14266 (CVSS 7.0) is a heap-based buffer overflow in 7-Zip's XZ decoder (MixCoder_Code in C/XzDec.c): specially crafted XZ chunked data is written past its allocated buffer, giving arbitrary code execution in the user's context when a victim opens or extracts a malicious archive. It affects 7-Zip 21.07 through 26.01 and is fixed in 26.02 (released 25 Jun; ZDI advisory ZDI-26-444 published 15 Jul). No public PoC or in-the-wild exploitation was observed as of 20 Jul, but the enormous install base and the routine use of archives as phishing attachments make this a high-value client-side RCE. 7-Zip has no auto-update mechanism, so unmanaged installs stay vulnerable indefinitely - push 26.02 across the estate and check for portable/standalone copies and bundled 7z binaries inside other tooling.

PoC: No public PoC and no in-the-wild exploitation as of 20 Jul (ZDI-26-444, published 15 Jul) - zerodayinitiative.com

Refs: thehackernews.com · socradar.io · bleepingcomputer.com

CVE-2026-57433 - Perl Storable SX_HOOK integer overflow on untrusted deserialization (patch 3.41)

HIGH

VERIFIED

Perl

Deserialization

DoS

CVE-2026-57433 (CWE-190) is a signed integer overflow in Perl's Storable serialization module before 3.41. `retrieve_hook_common` reads a signed 32-bit item count from a crafted `SX_HOOK` record and calls `av_extend` with that count plus one; a count of `I32_MAX` wraps the addition to a negative value, and `av_extend` then dies with a panic - terminating the deserialization. Authoritative advisories (openwall/oss-security, Ubuntu, Debian, NVD) characterise the impact as a denial-of-service/abort when `thaw()` or `retrieve()` processes attacker-controlled data, tempering an initial single-source 'CVSS 9.8 no-auth RCE' framing captured in the vault. Storable is embedded across many caching, session and queue layers that deserialize external input. Upgrade Storable to 3.41 across all Perl environments and never `thaw/retrieve` untrusted blobs.

Refs: openwall.com · ubuntu.com · security-tracker.debian.org

GLOBAL - SOFTWARE SUPPLY CHAIN

Dev & registry targeting

No Global items identified this reporting window.

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

wp2shell exploit toolkit released - WordPress Core pre-auth RCE (CVE-2026-63030 + CVE-2026-60137)

HIGH

VERIFIED

Exploit

WordPress

RCE

A public wp2shell exploit toolkit (github.com/ikow/wp2shell) packaging the CVE-2026-63030 + CVE-2026-60137 pre-auth RCE chain against WordPress Core appeared within hours of the 17 Jul disclosure, alongside vendor confirmations of active in-the-wild exploitation (Wiz 'Exploitation in the Wild'; Greenbone 'Now Actively Exploited'). The repo bundles exploitation and remediation tooling and, together with the public wp2shell.com vulnerability checker, sharply lowers the barrier to mass exploitation of default 6.9.0-7.0.1 installs. Red teams can validate detections against the batch-route chain; blue teams should treat any unpatched WordPress instance as compromised, patch to 7.0.2/6.9.5 immediately, and alert on unauthenticated POSTs to `/wp-json/batch/v1`.

PoC: Public - exploit + remediation toolkit; released within hours of the 17 Jul disclosure; in-the-wild exploitation confirmed - github.com

Refs: github.com · wiz.io · greenbone.net

GLOBAL - MALWARE & CAMPAIGNS**MemGhost - one email plants persistent false memories in inbox-reading AI agents**

HIGH

VERIFIED

AI-Agent

MemoryPoisoning

PromptInjection

MemGhost is a memory-poisoning attack against inbox-reading AI assistants: a single crafted email rewrites what a persistent agent 'remembers' about its user. Rather than a transient prompt injection, the poison is written to core context files (OpenClaw's plain-text `AGENTS.md` / `MEMORY.md`) that load at the start of every session - so it survives context clears and later steers unrelated tool calls, recipients or approvals. In the paper (arXiv 2607.05189, 'When Claws Remember but Do Not Tell'), the one-shot payload framework achieves 87.5% end-to-end success against OpenClaw + GPT-5.4 and 71.4% against the Claude Code SDK + Sonnet 4.6, transferring across agent architectures (NanoClaw, Hermes Agent) and filesystem/vector (Mem0) memory backends, evaluated on the 108-case WhisperBench using a real IMAP/SMTP email workflow. No attachment execution or link click is needed - the agent ingesting the message body is sufficient, and anyone who knows the victim's email address can attempt it. Treat all agent-ingested content as untrusted data at the memory-write path (not just at prompt assembly), require explicit user confirmation for memory writes derived from third-party content, and log/segment agent memory by trust origin.

PoC: Public - research framework + WhisperBench benchmark (arXiv 2607.05189) - arxiv.org

Refs: arxiv.org · thehackernews.com · cybersecasia.net

GLOBAL - NOTABLE BREACHES

Tinder - alleged 600 million-record database advertised for sale (uncorroborated)

MEDIUM

UNVERIFIED

Breach

Dating

Alleged

A cybercrime-forum actor advertised what they claim is a database of ~600 million Tinder (Match Group) user records, surfaced by @DailyDarkWeb on 19 Jul. It remains unconfirmed and is retained UNVERIFIED: web searches found no corroborating outlet or Match Group/Tinder statement, and 600M far exceeds Tinder's commonly cited registered-user base - a classic sign of aggregated, scraped or recycled data rather than a fresh intrusion. For context, the only substantiated 2026 Match Group claims are far smaller (ShinyHunters' ~10M Match Group records in January; a separate ~32M Bumble claim). If ever substantiated, the dataset's sensitivity would elevate sextortion, doxing and targeted-phishing risk beyond ordinary credential-stuffing. Do not escalate as a confirmed breach without sample verification, schema review and vendor response; advise MFA and unique passwords for any accounts sharing credentials with consumer dating apps.

Refs: x.com/DailyDarkWeb

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-63030	CVE	WordPress 'wp2shell' pre-auth RCE (batch-route confusion); exploited, public PoC - fix 7.0.2/6.9.5	slcyber.io
CVE-2026-60137	CVE	WordPress WP_Query author__not_in SQLi; chained in wp2shell - fix 7.0.2/6.9.5	tenable.com
/wp-json/batch/v1 (and ?rest_route=/batch/v1)	URI path	wp2shell exploit route - WAF-block anonymous access; hunt unauth POSTs	rapid7.com
github[.]com/ikow/wp2shell	URL (exploit repo)	Public wp2shell exploit toolkit (CVE-2026-63030 + -60137)	github.com
CVE-2026-14266	CVE	7-Zip XZ decoder heap overflow -> client-side RCE (7.0) - fix 26.02	thehackernews.com
CVE-2026-57433	CVE	Perl Storable SX_HOOK signed integer overflow (DoS/panic) - fix 3.41	openwall.com
CVE-2026-53565	CVE	Citrix Secure Access / EPA Client privesc to SYSTEM (8.5) - fix 26.6.1.20 / 26.5.1.7	cybersecuritynews.com
CVE-2026-53566	CVE	Citrix Secure Access Client out-of-bounds read (6.8) - fix 26.6.1.20	cvefeed.io
leaked[.]at (ns: norah/pedro.ns.cloudflare[.]com)	Domain	New cybercrime forum advertising leaks (OSINT, 17 Jul)	x.com/DarkWebInfomer

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Same-day weaponisation of pre-auth RCE in ubiquitous default-install software

Why it matters: wp2shell was reachable pre-auth on default WordPress with zero plugins, and public PoC exploit code plus in-the-wild exploitation appeared within hours of the 17 Jul disclosure - even though a same-day patch and forced auto-updates existed. 7-Zip adds a client-side RCE with no auto-update path. The window between disclosure and mass exploitation is now measured in hours.

Watch for: unauthenticated POSTs to /wp-json/batch/v1 (and ?rest_route=/batch/v1); unpatched WordPress 6.9.0-7.0.1 and unmanaged/portable 7-Zip below 26.02; mass scanning and webshells/attacker-written files in web roots.

HIGH**AI-agent attacks move to the memory/trust-boundary layer**

Why it matters: MemGhost persists attacker-authored 'facts' into an agent's long-term memory from a single email, so clearing context does not remediate it and the poison silently steers later tool calls, recipients and approvals - 87.5% success against OpenClaw+GPT-5.4 and transferable across agent and memory-backend types.

Watch for: memory-write events sourced from inbox/third-party content; tampering or unexpected edits to AGENTS.md / MEMORY.md; agents asserting facts with no traceable user provenance; agents with email/tool access and no human-in-the-loop for memory writes.

HIGH**Developer workstations as the supply-chain entry point (DPRK / UNK_DeadDrop)**

Why it matters: Fake recruiter pitches and 'coding assignment' lures push developers to clone-and-run malicious repos that execute at open/install time (.vscode/tasks.json, npm lifecycle scripts). One compromised maintainer yields source, cloud/CI credentials and package-registry tokens - the entry stage of the DPRK package-supply-chain playbook.

Watch for: unsolicited recruiter/code-review/trial-task contacts; repos that auto-run on open (.vscode/tasks.json) or via preinstall/postinstall; developers cloning untrusted code on credentialed hosts instead of disposable VMs; unusual outbound from dev workstations post-clone.

MED**Client-side and endpoint-agent privilege escalation convert footholds to SYSTEM**

Why it matters: Citrix Secure Access/EPA privesc reaches SYSTEM from a standard local user, and 7-Zip gives client-side RCE via a malicious archive - both are favoured post-initial-access steps that turn a phishing or infostealer foothold into fuller control without touching the network edge.

Watch for: suspicious child processes or DLL loads from Citrix client service paths; unpatched Secure Access below 26.6.1.20 / EPA below 26.5.1.7; malicious-archive lures and 7-Zip processes spawning shells.

MED**Long-dwell APAC espionage with attribution-resistant tradecraft**

Why it matters: GoSerpent quietly harvested Southeast Asian government, police and biometric data with multi-year dwell, relaying traffic through compromised hosts to blend C2 - patient, infrastructure-focused tradecraft (possible TetrisPhantom overlap) that resists takedown and network attribution.

Watch for: anomalous outbound relaying / hosts acting as unexpected proxies; Go-based low-and-slow beaconing; LSASS access and credential-dumping on government/diplomatic endpoints; SOCKS5/Stowaway proxy artefacts.

MED**Inflated and recycled mega-breach claims**

Why it matters: The alleged 600M Tinder listing failed web corroboration - the only substantiated 2026 Match Group figures are far smaller (~10M ShinyHunters, ~32M Bumble). Forum sellers routinely inflate scraped or recycled data to raise perceived value, so headline record counts are a poor proxy for real exposure.

Watch for: sample verification, schema review and vendor/regulatory statements before escalating any large listing; recycled/aggregated datasets re-marketed as fresh intrusions; credential-stuffing spikes against consumer-app-linked accounts.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	WordPress -> 7.0.2 / 6.9.5 (wp2shell CVE-2026-63030 + CVE-2026-60137); 7-Zip -> 26.02 (CVE-2026-14266); Perl Storable -> 3.41 (CVE-2026-57433); Citrix Secure Access Client -> 26.6.1.20 and EPA Client -> 26.5.1.7 (CVE-2026-53565/-53566). WordPress.org forced auto-updates, but confirm managed/hardened and multisite installs actually updated.
Emergency / exploited	wp2shell is actively exploited with public PoC. If a WordPress instance cannot be patched immediately, block anonymous access to /wp-json/batch/v1 and ?rest_route=/batch/v1 at the WAF, and treat any unpatched 6.9.0-7.0.1 site as potentially compromised - hunt for webshells and unauthenticated batch-route POSTs.
Block IOCs	Add the IOC-table indicators to firewall/WAF/EDR/SIEM and alert on the listed CVEs: the wp2shell CVEs + /wp-json/batch/v1 route + github[.]com/ikow/wp2shell exploit repo; the 7-Zip, Perl Storable and Citrix CVEs; and the leaked[.]at forum domain. Re-fang defanged indicators before importing.
Assume compromise	Treat internet-facing WordPress 6.9.0-7.0.1 as potentially breached - hunt for webshells, attacker-written files under the web root and unauthenticated POSTs to the batch route; rotate WordPress secrets, salts and any DB/API credentials reachable from the app.
Supply chain	Never clone-and-run code from unsolicited recruiter/code-review contacts on a credentialed host - use a disposable VM/container with no host mounts, SSH agent or cloud profile; run installs with --ignore-scripts; review package.json scripts and .vscode/tasks.json before opening a repo; rotate developer, cloud, CI, registry-token, wallet and SSH secrets if exposed.
AI / agents	Treat all agent-ingested email/documents/web content as untrusted data at the memory-write path, not just at prompt assembly; require explicit user confirmation for memory writes derived from third-party content; log, provenance-tag and segment agent memory by trust origin; red-team agent deployments for memory persistence, not just single-turn prompt injection.
Endpoints	Inventory and patch Citrix Secure Access/EPA clients and hunt for privesc via the Citrix client service paths; push 7-Zip 26.02 to unmanaged and portable installs (no auto-update); enforce the vulnerable-driver blocklist and standard EDR coverage on developer and VPN-agent endpoints.
People & monitoring	Brief developers that 'recruiter sent me a coding assignment' is now a primary DPRK access vector; monitor APAC government/diplomatic endpoints for GoSerpent relaying and Go-based beacons; verify large breach claims (e.g. Tinder 600M) with sample/schema checks before escalation or customer comms.